

## DETECÇÃO DE PÁGINAS DE *PHISHING* COM REDES NEURAIS AUTO-ESTRUTURANTES: RESUMO E CRÍTICA

### 1 CONTEXTO E MOTIVAÇÃO

Diferentemente de um *exploit*, que ataca uma falha de software, o *phishing* ataca o julgamento do usuário: uma página falsificada imita a de uma instituição legítima para obter credenciais. A defesa clássica são as listas de bloqueio, mas elas são intrinsecamente reativas — só barram o que já foi reportado e verificado, e a maior parte das vítimas de uma campanha é capturada nas primeiras horas, antes da entrada em lista [7]. A detecção precisa, portanto, ser *preditiva*: decidir sobre uma URL nunca vista.

Formulado assim, o problema é uma classificação binária supervisionada sobre atributos heterogêneos — tarefa para a qual uma Rede Neural Artificial (RNA) rasa é candidata natural. O trabalho de Mohammad *et al.* [1] é um dos exemplos mais citados dessa aplicação e tem a virtude didática de ser simples: um *perceptron* multicamadas com uma única camada oculta, treinado por retropropagação sobre 17 atributos. Sua contribuição não está na topologia, mas em automatizar a escolha do número de neurônios ocultos.

### 2 RESUMO DA APLICAÇÃO

**(a) Representação do problema.** Os 17 atributos vêm de três fontes: a própria URL (endereço IP no lugar do domínio, comprimento, símbolo “@”, hífen, subdomínios, encurtadores), o código-fonte da página (destino dos *links* âncora e do formulário, submissão para *e-mail*, *iframes*, desativação do botão direito, redirecionamentos) e serviços de terceiros (idade e prazo de registro do domínio via WHOIS, indexação em buscador, PageRank, tráfego). Cada atributo é discretizado em três valores — legítimo, suspeito e *phishing* (1, 0, -1) — por regras heurísticas definidas em trabalho anterior do mesmo grupo [2]. A entrada da rede é, assim, um vetor de 17 posições ternárias, e a saída, um único neurônio para a classe.

**(b) Rede, treinamento e auto-estruturação.** A rede é direta (*feedforward*), com uma camada oculta, pesos iniciados em valores aleatórios pequenos e ajuste por retropropagação do erro. O ponto do artigo está no dimensionamento: em vez de fixar o número de neurônios ocultos por tentativa e erro, o procedimento: (i) parte de uma estrutura mínima; (ii) executa uma única época para medir a taxa de erro corrente e dela derivar a taxa de erro desejada; (iii) treina até atingir essa meta, esgotar o orçamento de épocas ou disparar a parada antecipada; e (iv) caso a meta não seja atingida, acrescenta um neurônio à camada oculta e repete. A justificativa oferecida é de domínio, não de otimização: como os atributos que distinguem *phishing* mudam continuamente, a topologia não pode ser um artefato fixado uma única vez — ela precisa ser **re-derivável** a cada reconstrução do modelo.

**(c) Avaliação.** O conjunto reúne 1.400 páginas — 600 legítimas e 800 de *phishing* — coletadas dos arquivos do PhishTank e do MillerSmiles. Variando o orçamento de épocas, a configuração com 1.000 épocas alcançou **92,18% de acurácia** em teste, e os autores relatam

boa capacidade de generalização em todas as estruturas produzidas. O conjunto de atributos foi depois estendido para 30 e publicado no repositório UCI, tornando-se um dos *benchmarks* mais reutilizados da literatura de *phishing*.

### 3 CRÍTICA

#### 3.1 Méritos

Dois merecem registro. Primeiro, **a auto-estruturação parte de uma premissa correta sobre o domínio**: *phishing* é fenômeno adversarial e não estacionário, e todo hiperparâmetro ajustado à mão sobre um instantâneo envelhece com ele; automatizar a topologia é reconhecer que o modelo será reconstruído muitas vezes. Segundo, **as entradas são interpretáveis**: cada posição do vetor corresponde a uma propriedade nomeável da página, o que permite auditar a decisão ao menos no nível da entrada. Some-se a publicação do conjunto de dados, hoje *benchmark* comum da área.

#### 3.2 Onde está o mérito: na RNA ou na engenharia de atributos?

A objeção central é que **o artigo não demonstra que precisava de uma rede neural**. Os 17 atributos não são medidas brutas: chegam já discretizados em  $\{-1, 0, 1\}$  por regras de especialista que embutem o conhecimento de detecção. A parte difícil foi resolvida *antes* da rede. Sobre uma entrada ternária e de baixa dimensionalidade, o que resta é próximo de uma contagem ponderada de indícios, que árvores de decisão ou classificadores associativos resolvem com desempenho comparável e explicação legível, como o próprio grupo mostrou depois com mineração associativa [3]. O artigo não reporta nenhuma linha de base não neural — omissão que corresponde ao pecado de *inappropriate baseline* catalogado por Arp *et al.* [4]. Sem esse controle, os 92% medem a facilidade do conjunto, não a capacidade do modelo.

#### 3.3 Viés de amostragem e correlação espúria

A composição dos dados merece escrutínio. As amostras maliciosas vêm do PhishTank — páginas já reportadas e confirmadas por voluntários —, viés de sobrevivência que privilegia campanhas grosseiras; as legítimas vêm de arquivos de sítios conhecidos. O efeito é que atributos como idade do domínio, PageRank, tráfego e indexação não codificam malícia: codificam **popularidade e maturidade**. O classificador pode estar aprendendo a separar “sítio popular e antigo” de “domínio recém-registrado”: funciona no conjunto e falha na prática, pois um serviço legítimo recém-lançado seria bloqueado e uma página maliciosa em domínio comprometido passaria. Marchal e Asokan [6] apontam esse tipo de escolha como causa da distância entre acurácia experimental e eficácia real.

#### 3.4 Viés temporal e obsolescência dos atributos

Há uma contradição interna instrutiva. O artigo justifica a auto-estruturação afirmando que os atributos relevantes mudam com o tempo, mas avalia por partição aleatória de um instantâneo único, sem separação temporal entre treino e teste — o **viés temporal** de Pendlebury

*et al.* [5], que infla a métrica e oculta a deriva. O exemplo mais didático é o atributo de certificado: em 2012, TLS válido era sinal forte de legitimidade; com a difusão de autoridades certificadoras gratuitas, a maioria das páginas de *phishing* passou a usar HTTPS e o atributo trocou de sinal. Vários atributos de terceiros sequer existem hoje — o PageRank público foi descontinuado —, e o modelo publicado **não é reproduzível** sem redefinir suas entradas. Nenhuma avaliação longitudinal é apresentada, embora a tese do artigo exigisse medir a taxa de decaimento.

### 3.5 Métrica, taxa-base e custo assimétrico

Reportar acurácia sobre um conjunto quase balanceado é a escolha menos informativa possível. Em operação, a prevalência de *phishing* é ordens de grandeza menor, e vale a falácia da taxa-base de Axelsson [8]: sob baixa prevalência, mesmo uma taxa de falsos positivos pequena domina o conjunto de alertas. Os dois erros tampouco custam o mesmo — bloquear indevidamente o sítio do banco do usuário leva à desativação da ferramenta, enquanto um falso negativo permanece invisível até o dano ocorrer. Nada disso é discutido: não há limiar orientado a custo, nem a decomposição dos 7,82% de erro entre falsos positivos e negativos.

### 3.6 Ausência de modelo de ameaça

Por fim, o trabalho trata *phishing* como classificação estática, e não como jogo. A maior parte dos 17 atributos está sob controle direto do atacante e custa quase nada evadir: não usar “@”, evitar encurtadores, registrar o domínio com antecedência, obter um certificado gratuito. Publicado o conjunto de atributos — e os autores publicaram exatamente isso —, o custo de evasão para um adversário informado tende a zero. Os atributos de terceiros ainda exigem consultas WHOIS e de indexação por URL, o que impõe latência e vaza o histórico do usuário ao serviço consultado.

## 4 CONSIDERAÇÕES FINAIS

Como exemplo didático de RNA aplicada à segurança, o trabalho é excelente: o problema é real, a representação é legível, a arquitetura é simples e a auto-estruturação resolve um incômodo prático de modo elegante. Como evidência de que uma rede neural era *necessária*, ele não convence — e essa distinção é a lição a extrair. Quando a engenharia de atributos já embute o conhecimento do especialista e reduz o problema a 17 sinais ternários, o classificador que fecha a decisão é a parte barata; medir apenas sua acurácia sobre um instantâneo balanceado, sem linha de base trivial, sem eixo temporal e sem adversário, é medir a facilidade dos dados, não a competência do modelo.

A observação se transfere para outros domínios: em subestações digitais sob a norma IEC 61850, o tráfego GOOSE é periódico e restrito por especificação, e boa parte do comportamento normal pode ser *declarada* em vez de aprendida. A RNA é a ferramenta certa onde o normal é complexo, mutável e não especificável; onde não é, ela cobra o preço da opacidade sem entregar o ganho.

## REFERÊNCIAS

- [1] MOHAMMAD, R. M.; THABTAH, F.; McCLUSKEY, L. Predicting Phishing Websites Based on Self-Structuring Neural Network. *Neural Computing and Applications*, v. 25, n. 2, p. 443–458, 2014. DOI: 10.1007/s00521-013-1490-z.
- [2] MOHAMMAD, R. M.; THABTAH, F.; McCLUSKEY, L. An Assessment of Features Related to Phishing Websites Using an Automated Technique. In: *International Conference for Internet Technology and Secured Transactions (ICITST)*, Londres, 2012, p. 492–497.
- [3] ABDELHAMID, N.; AYESH, A.; THABTAH, F. Phishing Detection Based Associative Classification Data Mining. *Expert Systems with Applications*, v. 41, n. 13, p. 5948–5959, 2014.
- [4] ARP, D.; QUIRING, E.; PENDLEBURY, F.; WARNECKE, A.; PIERAZZI, F.; WRESSNEGGER, C.; CAVALLARO, L.; RIECK, K. Dos and Don'ts of Machine Learning in Computer Security. In: *31st USENIX Security Symposium*, Boston, 2022, p. 3971–3988.
- [5] PENDLEBURY, F.; PIERAZZI, F.; JORDANEY, R.; KINDER, J.; CAVALLARO, L. TESSERACT: Eliminating Experimental Bias in Malware Classification across Space and Time. In: *28th USENIX Security Symposium*, Santa Clara, 2019, p. 729–746.
- [6] MARCHAL, S.; ASOKAN, N. On Designing and Evaluating Phishing Webpage Detection Techniques for the Real World. In: *11th USENIX Workshop on Cyber Security Experimentation and Test (CSET)*, Baltimore, 2018.
- [7] OEST, A.; ZHANG, P.; WARDMAN, B.; NUNES, E.; BURGIS, J.; ZAND, A.; THOMAS, K.; DOUPÉ, A.; AHN, G.-J. Sunrise to Sunset: Analyzing the End-to-end Life Cycle and Effectiveness of Phishing Attacks at Scale. In: *29th USENIX Security Symposium*, 2020, p. 361–377.
- [8] AXELSSON, S. The Base-Rate Fallacy and its Implications for the Difficulty of Intrusion Detection. In: *6th ACM Conference on Computer and Communications Security (CCS)*, Singapura, 1999, p. 1–7.